常见的物联网攻击方式（网络、硬件）定义

安全机制是什么（硬件：熔断、看门狗、PUF、ROT、可信执行环境；软件：沙盒、蜜罐；无线：TLS）

物联网安全

与传统网络相比，物联网的攻击面更为广大

1. **总体目标**：数据可信、访问可控、敏感信息保密、服务持续可用
2. **全生命周期管理**：身份配置、密钥轮换、固件更新、撤销与退役
3. **六类安全要求**：身份与权限；来源、完整性与时效；机密性与隐私；代码与密钥保护；可用性与恢复；维护与追溯。

物联网攻击

网络层面

1. **被动式攻击**：通常在不引起合法用户或者系统的觉察下，主要以`嗅探、扫描、窃听`等方式开展，其目标涵盖目标系统的端口、信道和潜在漏洞。
2. **主动式攻击**：通常会造成**系统和信息的更改或转换**，不仅会产生信息的泄漏，还会对系统的完整性和可用性构成威胁
   a. **假冒攻击**：冒充合法设备或用户
   b. **信息篡改**：对窃听到的信息进行修改再传递
   c. **重放/重传攻击**：将窃听到的信息经过一段时间后再传
   d. **拒绝服务攻击**：使目标节点无法向其他合法节点提供正常服务
   e. **干扰攻击**：通过发出**干扰射频**实现破坏无线通信的目的
   f. **病毒与恶意软件**：破坏网络通信节点运行，或控制设备执行攻击者指令

硬件层面

1. **故障注入攻击**：引入某些外部因素使**系统的运算或操作出现错误**，从而泄露系统敏感信息
   a. 常见于对**加密保护机制**的攻击
2. **接口植入攻击**：通过**串口连接和访问**获得shell、日志输出等关键信息
3. **逆向工程**：通过读取**硬件存储器中的固件**来得到用户关键信息，也可能修改后刷回
4. **侧信道攻击**：硬件进行加密等运算时会产生声音、温度、功耗、电磁等侧信道信息，这些附带产生的物理量会体现计算或操作的特征

安全机制

硬件安全机制

1. **熔断机制**：在MCU或CPU等芯片特定引脚外加高电平后，可以通过产生的电流烧断里边的熔丝，进而使芯片里的程序变为**不可读写，只能运行**
2. **看门狗Watchdog**：本质是一个电子或软件计时器
   a. 正常运行时定期重置；发生硬件故障或程序错误时无法重置，达到超时条件时，系统重启
   b. 分为软件/硬件看门狗

3. **PUF物理不可克隆函数**：利用芯片制造过程中的**微小物理差异**产生独特响应，相当于硬件“**指纹**”，可用于设备身份识别和密钥派生，**难以复制**。
4. **RoT信任根**：是建立信任链的来源，也是SoC的安全根基，所有后续组件的可信度都依赖于可信根的初始可信状态，例如硬件安全模块HSM。
5. **TEE可信执行环境**：将软硬件资源划分为**安全世界与非安全世界**。
    - **CA客户端应用**在普通环境运行，**TA可信应用**在安全环境运行。

软件

> **漏洞（Vulnerability）**是指系统中存在的一些功能性或安全性的逻辑缺陷
>
> 漏洞挖掘技术，漏洞分析技术

1. **软件混淆**：程序代码转换为功能等价但是难以理解的形式
2. **沙盒**：一种安全机制，为运行中的程序提供的隔离环境
    a. **安全栈保护返回地址，栈界限限制栈访问范围。**
3. **蜜罐**：将模拟设备、服务和接口作为**诱饵**，捕获并分析攻击活动
    a. 开源物联网蜜罐：Potd（重定向器+协议进程+监视器）
    b. **诱饵环境：重定向器+协议进程；为攻击者提供入侵的通信接口。**

> **OTA安全**：空中下载技术，**在线**更新固件，**及时修复漏洞**，OTA过程易遭受攻击

无线

1. **蓝牙安全**：4种安全模式，数字越大级别越高
2. ZigBee安全：在每个层面都有相应的安全设计
3. **LoRaWan安全**：NwkSKey 与AppSKey共同建立了终端-网络层、终端-应用层的**双向认证**。
    a. **AppKey**：根密钥，用于入网认证与会话密钥派生。
    b. **NwkSKey**：网络层完整性保护。
    c. **AppSKey**：应用载荷加密。

认证与传输

1. **伪造热点**
2. **传输安全TLS**：前身为SSL协议，传输层与网络层之间
    a. 在**传输层**对**网络连接**进行加密，提供**机密性和完整性保障**
    b. **HTTPS＝HTTP＋TLS**；MQTT也可以通过TLS保护连接。